SSP Assessment - lab03-target - Oct 2026

NIST SP 800-53 revision 5

National Institute of Standards and Technology - Special Publication 800-53 - Security and Privacy Controls for Information Systems and Organizations

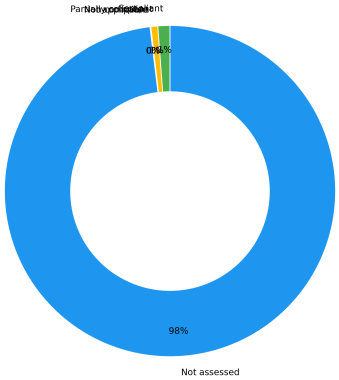
Reference	ASMT-001
Date	19/10/2026
Implementation groups	All
Contributors	sarfogideon@gmail.com,

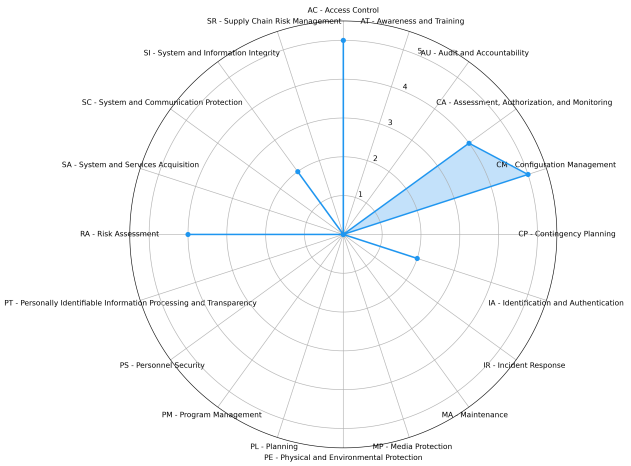
Generated at 2026-10-19 22:13:08 UTC
Document ID `9289d8bf-a037-490e-b2e8-947fb4bc1d62`

Executive summary

Compliant	Partially compliant	Non compliant	Not applicable	Not assessed
14	8	1	0	1166

Compliant on **1.2%** of 1189 assessed requirements. 0 applied controls are linked to this audit.





Scope

Tailored NIST SP 800-53 Rev 5 assessment of lab03-target (FIPS 199 Low) supporting the Lab 04 System Security Plan. Scope limited to 23 controls evidenced by Labs 01–03.

Drifts per domain

Domain	Findings
AC - Access Control	141
AT - Awareness and Training	17
AU - Audit and Accountability	69
CA - Assessment, Authorization, and Monitoring	31
CM - Configuration Management	63
CP - Contingency Planning	56
IA - Identification and Authentication	69
IR - Incident Response	42
MA - Maintenance	30
MP - Media Protection	30
PE - Physical and Environmental Protection	59
PL - Planning	17
PM - Program Management	37
PS - Personnel Security	18
PT - Personally Identifiable Information Processing and Transparency	21
RA - Risk Assessment	25
SA - System and Services Acquisition	145
SC - System and Communication Protection	162
SI - System and Information Integrity	116
SR - Supply Chain Risk Management	27

Detailed results

1189 assessable requirements.

AC-1 — Policy and Procedures

Not assessed

Progress: To do

a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:
1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] access control policy that:
(a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
(b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and
2. Procedures to facilitate the implementation of the access control policy and the associated access controls;
b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the access control policy and procedures; and
c. Review and update the current access control:
1. Policy [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]; and
2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events].

AC-2 — Account Management

Partially compliant

Progress: Done

a. Define and document the types of accounts allowed and specifically prohibited for use within the system;
b. Assign account managers;
c. Require [Assignment: organization-defined prerequisites and criteria] for group and role membership;
d. Specify:
1. Authorized users of the system;
2. Group and role membership; and
3. Access authorizations (i.e., privileges) and [Assignment: organization-defined attributes (as required)] for each account;
e. Require approvals by [Assignment: organization-defined personnel or roles] for requests to create accounts;
f. Create, enable, modify, disable, and remove accounts in accordance with [Assignment: organization-defined policy, procedures, prerequisites, and criteria];
g. Monitor the use of accounts;
h. Notify account managers and [Assignment: organization-defined personnel or roles] within:
1. [Assignment: organization-defined time period] when accounts are no longer required;
2. [Assignment: organization-defined time period] when users are terminated or transferred; and
3. [Assignment: organization-defined time period] when system usage or need-to-know changes for an individual;
i. Authorize access to the system based on:
1. A valid access authorization;
2. Intended system usage; and
3. [Assignment: organization-defined attributes (as required)];
j. Review accounts for compliance with account management requirements [Assignment: organization-defined frequency];
k. Establish and implement a process for changing shared or group account authenticators (if deployed) when individuals are removed from the group; and
l. Align account management processes with personnel termination and transfer processes.

“Observation”: lab03-target has two interactive accounts: gsarfo (system administrator) and gvmscan (dedicated scan account used only by GVM). Each account has a single documented purpose and is explicitly listed in the SSH AllowUsers directive. Inactive accounts are handled through periodic account review in place of password-expiry disablement (see password-aging risk acceptance memo). Gap: no documented emergency/break-glass account or recovery procedure; account review is not yet recorded on a schedule.

“Evidences”: Lab 03 risk acceptance, Lab 03 hardening screenshots (05-09)

AC-2(1) — Account Management | Automated System Account Management

Not assessed

Progress: To do

Support the management of system accounts using [Assignment: organization-defined automated mechanisms].

AC-2(2) — Account Management | Automated Temporary and Emergency Account Management

Not assessed

Progress: To do

Enforce [Assignment: organization-defined circumstances and/or usage conditions] for [Assignment: organization-defined system accounts].

AC-2(12) — Account Management | Account Monitoring for Atypical Usage

Not assessed

Progress: To do

(a) Monitor system accounts for [Assignment: organization-defined atypical usage]; and
(b) Report atypical usage of system accounts to [Assignment: organization-defined personnel or roles].

AC-2(13) — Account Management | Disable Accounts for High-risk Individuals

Not assessed

Progress: To do

Disable accounts of individuals within [Assignment: organization-defined time period] of discovery of [Assignment: organization-defined significant risks].

AC-3 — Access Enforcement

Compliant

Progress: Done

Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

“Observation”: Boot-time access is enforced by a GRUB superuser (grubadmin) with a PBKDF2-hashed password: normal boot is unrestricted, but editing boot entries requires the password and recovery entries are disabled. AppArmor is enabled at boot. sudo access is restricted and secure_path excludes /snap/bin. Remaining AppArmor profiles not in enforce/complain mode are tracked separately.

“Evidences”: Lab 03 OpenSCAP reports & tailoring, Lab 03 hardening screenshots (05-09)

AC-14(1) — Permitted Actions Without Identification or Authentication | Necessary Uses

Not assessed

Progress: To do

[Withdrawn: Incorporated into AC-14.]

AC-3(2) — Access Enforcement | Dual Authorization

Not assessed

Progress: To do

Enforce dual authorization for [Assignment: organization-defined privileged commands and/or other organization-defined actions].

AC-3(3) — Access Enforcement | Mandatory Access Control

Not assessed

Progress: To do

Enforce [Assignment: organization-defined mandatory access control policy] over the set of covered subjects and objects specified in the policy, and where the policy:
(a) Is uniformly enforced across the covered subjects and objects within the system;
(b) Specifies that a subject that has been granted access to information is constrained from doing any of the following;
(1) Passing the information to unauthorized subjects or objects;
(2) Granting its privileges to other subjects;
(3) Changing one or more security attributes (specified by the policy) on subjects, objects, the system, or system components;
(4) Choosing the security attributes and attribute values (specified by the policy) to be associated with newly created or modified objects; and
(5) Changing the rules governing access control; and
(c) Specifies that [Assignment: organization-defined subjects] may explicitly be granted [Assignment: organization-defined privileges] such that they are not limited by any defined subset (or all) of the above constraints.

AC-3(4) — Access Enforcement | Discretionary Access Control

Not assessed

Progress: To do

When transferring information between different security domains, the process that transfers information between filter pipelines:
(a) Does not filter message content;
(b) Validates filtering metadata;
(c) Ensures the content associated with the filtering metadata has successfully completed filtering; and
(d) Transfers the content to the destination filter pipeline.

AC-5 — Separation of Duties

Not assessed

Progress: To do

a. Identify and document [Assignment: organization-defined duties of individuals requiring separation]; and
b. Define system access authorizations to support separation of duties.

AC-6 — Least Privilege

Compliant

Progress: Done

Employ the principle of least privilege, allowing only authorized accesses for users (or processes acting on behalf of users) that are necessary to accomplish assigned organizational tasks.

“Observation”: Root login over SSH is disabled; administrative actions require sudo by the named administrator. The gvmscan account exists solely for authenticated scanning and is not used interactively. sudo secure_path was restricted (/etc/sudoers.d/10-secure-path) and validated with visudo -c. A stricter default umask prevents root-created files from being readable by other users.

“Evidences”: Lab 03 OpenSCAP reports & tailoring, Lab 03 hardening screenshots (05-09)

AC-6(1) — Least Privilege | Authorize Access to Security Functions

Not assessed

Progress: To do

Authorize access for [Assignment: organization-defined individuals or roles] to:
(a) [Assignment: organization-defined security functions (deployed in hardware, software, and firmware)]; and
(b) [Assignment: organization-defined security-relevant information].

AC-6(2) — Least Privilege | Non-privileged Access for Nonsecurity Functions

Not assessed

Progress: To do

Require that users of system accounts (or roles) with access to [Assignment: organization-defined security functions or security-relevant information] use non-privileged accounts or roles, when accessing nonsecurity functions.

AC-6(3) — Least Privilege | Network Access to Privileged Commands

Not assessed

Progress: To do

Authorize network access to [Assignment: organization-defined privileged commands] only for [Assignment: organization-defined compelling operational needs] and document the rationale for such access in the security plan for the system.

AC-6(4) — Least Privilege | Separate Processing Domains

Not assessed

Progress: To do

Provide separate processing domains to enable finer-grained allocation of user privileges.

AC-6(5) — Least Privilege | Privileged Accounts

Not assessed

Progress: To do

Restrict privileged accounts on the system to [Assignment: organization-defined personnel or roles].

AC-6(6) — Least Privilege | Privileged Access by Non-organizational Users

Not assessed

Progress: To do

Prohibit privileged access to the system by non-organizational users.

AC-6(7) — Least Privilege | Review of User Privileges

Not assessed

Progress: To do

(a) Review [Assignment: organization-defined frequency] the privileges assigned to [Assignment: organization-defined roles or classes of users] to validate the need for such privileges; and
(b) Reassign or remove privileges, if necessary, to correctly reflect organizational mission and business needs.

AC-6(8) — Least Privilege | Privilege Levels for Code Execution

Not assessed

Progress: To do

Prevent the following software from executing at higher privilege levels than users executing the software: [Assignment: organization-defined software].

AC-6(9) — Least Privilege | Log Use of Privileged Functions

Not assessed

Progress: To do

Log the execution of privileged functions.

AC-6(10) — Least Privilege | Prohibit Non-privileged Users from Executing Privileged Functions

Not assessed

Progress: To do

Prevent non-privileged users from executing privileged functions.

AC-7 — Unsuccessful Logon Attempts

Compliant

Progress: Done

a. Enforce a limit of [Assignment: organization-defined number] consecutive invalid logon attempts by a user during a [Assignment: organization-defined time period]; and
b. Automatically [Selection (one or more): lock the account or node for an [Assignment: organization-defined time period]; lock the account or node until released by an administrator; delay next logon prompt per [Assignment: organization-defined delay algorithm]; notify system administrator; take other [Assignment: organization-defined action]] when the maximum number of unsuccessful attempts is exceeded.

“Observation”: pam_faillock locks an account after 4 consecutive failed authentication attempts, including mistyped sudo passwords. SSH limits authentication attempts per connection and applies login delays. Effectiveness was demonstrated during the lab when the administrator account locked and required faillock --reset, and when the GVM default-credential brute-force check timed out against the hardened service.

“Evidences”: Lab 03 hardening screenshots (05-09), Lab 03 GVM authenticated scans

AC-17(8) — Remote Access | Disable Nonsecure Network Protocols

Not assessed

Progress: To do

[Withdrawn: Incorporated into CM-7.]

AC-7(2) — Unsuccessful Logon Attempts | Purge or Wipe Mobile Device

Not assessed

Progress: To do

Purge or wipe information from [Assignment: organization-defined mobile devices] based on [Assignment: organization-defined purging or wiping requirements and techniques] after [Assignment: organization-defined number] consecutive, unsuccessful device logon attempts.

AC-7(3) — Unsuccessful Logon Attempts | Biometric Attempt Limiting

Not assessed

Progress: To do

Limit the number of unsuccessful biometric logon attempts to [Assignment: organization-defined number].

AC-7(4) — Unsuccessful Logon Attempts | Use of Alternate Authentication Factor

Not assessed

Progress: To do

(a) Allow the use of [Assignment: organization-defined authentication factors] that are different from the primary authentication factors after the number of organization-defined consecutive invalid logon attempts have been exceeded; and
(b) Enforce a limit of [Assignment: organization-defined number] consecutive invalid logon attempts through use of the alternative factors by a user during a [Assignment: organization-defined time period].

AC-8 — System Use Notification

Compliant

Progress: Done

a. Display [Assignment: organization-defined system use notification message or banner] to users before granting access to the system that provides privacy and security notices consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines and state that:
1. Users are accessing a U.S. Government system;
2. System usage may be monitored, recorded, and subject to audit;
3. Unauthorized use of the system is prohibited and subject to criminal and civil penalties; and
4. Use of the system indicates consent to monitoring and recording;
b. Retain the notification message or banner on the screen until users acknowledge the usage conditions and take explicit actions to log on to or further access the system; and
c. For publicly accessible systems:
1. Display system use information [Assignment: organization-defined conditions], before granting further access to the publicly accessible system;
2. Display references, if any, to monitoring, recording, or auditing that are consistent with privacy accommodations for such systems that generally prohibit those activities; and
3. Include a description of the authorized uses of the system.

“Observation”: A system use banner is displayed before SSH authentication and on local login, applied by the CIS Level 1 remediation script and verified during second-session SSH testing.

“Evidences”: Lab 03 OpenSCAP reports & tailoring

AC-9 — Previous Logon Notification

Not assessed

Progress: To do

Notify the user, upon successful logon to the system, of the date and time of the last logon.

AC-9(1) — Previous Logon Notification | Unsuccessful Logons

Not assessed

Progress: To do

Notify the user, upon successful logon, of the number of unsuccessful logon attempts since the last successful logon.

AC-9(2) — Previous Logon Notification | Successful and Unsuccessful Logons

Not assessed

Progress: To do

Notify the user, upon successful logon, of the number of [Selection: successful logons; unsuccessful logon attempts; both] during [Assignment: organization-defined time period].

AC-9(3) — Previous Logon Notification | Notification of Account Changes

Not assessed

Progress: To do

Notify the user, upon successful logon, of changes to [Assignment: organization-defined security-related characteristics or parameters of the user’s account] during [Assignment: organization-defined time period].

AC-9(4) — Previous Logon Notification | Additional Logon Information

Not assessed

Progress: To do

Notify the user, upon successful logon, of the following additional information: [Assignment: organization-defined additional information].

AC-10 — Concurrent Session Control

Not assessed

Progress: To do

Limit the number of concurrent sessions for each [Assignment: organization-defined account and/or account type] to [Assignment: organization-defined number].

AC-11 — Device Lock

Not assessed

Progress: To do

a. Prevent further access to the system by [Selection (one or more): initiating a device lock after [Assignment: organization-defined time period] of inactivity; requiring the user to initiate a device lock before leaving the system unattended]; and
b. Retain the device lock until the user reestablishes access using established identification and authentication procedures.

AC-11(1) — Device Lock | Pattern-hiding Displays

Not assessed

Progress: To do

Conceal, via the device lock, information previously visible on the display with a publicly viewable image.

AC-12 — Session Termination

Compliant

Progress: Done

Automatically terminate a user session after [Assignment: organization-defined conditions or trigger events requiring session disconnect].

“Observation”: Idle SSH sessions are terminated after approximately 15 minutes of inactivity through ClientAliveInterval/ClientAliveCountMax settings in the hardened sshd configuration.

“Evidences”: Lab 03 OpenSCAP reports & tailoring

AC-12(1) — Session Termination | User-initiated Logouts

Not assessed

Progress: To do

Provide a logout capability for user-initiated communications sessions whenever authentication is used to gain access to [Assignment: organization-defined information resources].

AC-12(2) — Session Termination | Termination Message

Not assessed

Progress: To do

Display an explicit logout message to users indicating the termination of authenticated communications sessions.

AC-12(3) — Session Termination | Timeout Warning Message

Not assessed

Progress: To do

Display an explicit message to users indicating that the session will end in [Assignment: organization-defined time until end of session].

AC-18(2) — Wireless Access | Monitoring Unauthorized Connections

Not assessed

Progress: To do

[Withdrawn: Incorporated into SI-4.]

AC-14 — Permitted Actions Without Identification or Authentication

Not assessed

Provide the capability to associate [Assignment: organization-defined security and privacy attributes] with [Assignment: organization-defined subjects and objects] by authorized individuals (or processes acting on behalf of individuals).

AC-16(5) — Security and Privacy Attributes | Attribute Displays on Objects to Be Output

Not assessed

Progress: To do

Display security and privacy attributes in human-readable form on each object that the system transmits to output devices to identify [Assignment: organization-defined special dissemination, handling, or distribution instructions] using [Assignment: organization-defined human-readable, standard naming conventions].

AC-16(6) — Security and Privacy Attributes | Maintenance of Attribute Association

Not assessed

Progress: To do

Require personnel to associate and maintain the association of [Assignment: organization-defined security and privacy attributes] with [Assignment: organization-defined subjects and objects] in accordance with [Assignment: organization-defined security and privacy policies].

AC-16(7) — Security and Privacy Attributes | Consistent Attribute Interpretation

Not assessed

Progress: To do

Provide a consistent interpretation of security and privacy attributes transmitted between distributed system components.

AC-16(8) — Security and Privacy Attributes | Association Techniques and Technologies

Not assessed

Progress: To do

Implement [Assignment: organization-defined techniques and technologies] in associating security and privacy attributes to information.

AC-16(9) — Security and Privacy Attributes | Attribute Reassignment — Regrading Mechanisms

Not assessed

Progress: To do

Change security and privacy attributes associated with information only via regrading mechanisms validated using [Assignment: organization-defined techniques or procedures].

AC-16(10) — Security and Privacy Attributes | Attribute Configuration by Authorized Individuals

Not assessed

Progress: To do

Provide authorized individuals the capability to define or change the type and value of security and privacy attributes available for association with subjects and objects.

AC-17 — Remote Access

Compliant

Progress: Done

a. Establish and document usage restrictions, configuration/connection requirements, and implementation guidance for each type of remote access allowed; and
b. Authorize each type of remote access to the system prior to allowing such connections.

“Observation”: Remote administration is permitted only over SSH. The host firewall (ufw) allows SSH only from the LabNet subnet 10.0.5.0/24. AllowUsers restricts SSH to gsarfo and gvmscan; root login is disabled; empty passwords are rejected; and SSH is restricted to hardened ciphers, MACs, and key exchange algorithms. The host ED25519 key fingerprint was verified on first connection.

“Evidences”: Lab 03 OpenSCAP reports & tailoring, Lab 03 hardening screenshots (05-09)

AC-17(1) — Remote Access | Monitoring and Control

Not assessed

Progress: To do

Progress: To do

[Withdrawn: Incorporated into PM-15.]

AT-6 — Training Feedback

Not assessed

Progress: To do

Provide feedback on organizational training results to the following personnel [Assignment: organization-defined frequency]: [Assignment: organization-defined personnel].

AU-1 — Policy and Procedures

Not assessed

Progress: To do

a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:
1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] audit and accountability policy that:
(a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
(b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and
2. Procedures to facilitate the implementation of the audit and accountability policy and the associated audit and accountability controls;
b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the audit and accountability policy and procedures; and
c. Review and update the current audit and accountability:
1. Policy [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]; and
2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events].

AU-2 — Event Logging

Partially compliant

Progress: Done

a. Identify the types of events that the system is capable of logging in support of the audit function: [Assignment: organization-defined event types that the system is capable of logging];
b. Coordinate the event logging function with other organizational entities requiring audit-related information to guide and inform the selection criteria for events to be logged;
c. Specify the following event types for logging within the system: [Assignment: organization-defined event types (subset of the event types defined in AU-2a.) along with the frequency of (or situation requiring) logging for each identified event type];
d. Provide a rationale for why the event types selected for logging are deemed to be adequate to support after-the-fact investigations of incidents; and
e. Review and update the event types selected for logging [Assignment: organization-defined frequency].

“Observation”: System logging is provided by systemd-journald and rsyslog (rsyslog verified active 2026-10-19), configured to CIS Level 1 Server requirements, including sudo logging; log file permissions under /var/log were corrected and verified. The Linux audit daemon (auditd) is not active; auditd rules fall under CIS Level 2 and were outside the approved Level 1 baseline. Logs are retained locally only. Gap: no auditd event auditing, centralized log collection, or defined review process; planned for Lab 05 (Continuous Monitoring & Log Analysis).

“Evidences”: Lab 03 OpenSCAP reports & tailoring, Lab 04 logging & patching check

AU-10(5) — Non-repudiation | Digital Signatures

Not assessed

Progress: To do

[Withdrawn: Incorporated into SI-7.]

AU-14(2) — Session Audit | Capture and Record Content

Not assessed

Progress: To do

[Withdrawn: Incorporated into AU-14.]

AU-15 — Alternate Audit Logging Capability

Not assessed

AU-11(1) — Audit Record Retention | Long-term Retrieval Capability

Not assessed

Progress: To do

Employ [Assignment: organization-defined measures] to ensure that long-term audit records generated by the system can be retrieved.

AU-12 — Audit Record Generation

Partially compliant

Progress: Done

a. Provide audit record generation capability for the event types the system is capable of auditing as defined in AU-2a on [Assignment: organization-defined system components];
b. Allow [Assignment: organization-defined personnel or roles] to select the event types that are to be logged by specific components of the system; and
c. Generate audit records for the event types defined in AU-2c that include the audit record content defined in AU-3.

“Observation”: Audit records for authentication, sudo use, and system services are generated by journald and rsyslog under the CIS Level 1 baseline. Gap: auditd is not active, so kernel-level event auditing (file access, privileged command execution) is not generated, and records are not forwarded to a central collector or correlated; addressed in Lab 05.

“Evidences”: Lab 03 OpenSCAP reports & tailoring, Lab 04 logging & patching check

AU-12(1) — Audit Record Generation | System-wide and Time-correlated Audit Trail

Not assessed

Progress: To do

Compile audit records from [Assignment: organization-defined system components] into a system-wide (logical or physical) audit trail that is time-correlated to within [Assignment: organization-defined level of tolerance for the relationship between time stamps of individual records in the audit trail].

AU-12(2) — Audit Record Generation | Standardized Formats

Not assessed

Progress: To do

Produce a system-wide (logical or physical) audit trail composed of audit records in a standardized format.

AU-12(3) — Audit Record Generation | Changes by Authorized Individuals

Not assessed

Progress: To do

Provide and implement the capability for [Assignment: organization-defined individuals or roles] to change the logging to be performed on [Assignment: organization-defined system components] based on [Assignment: organization-defined selectable event criteria] within [Assignment: organization-defined time thresholds].

AU-12(4) — Audit Record Generation | Query Parameter Audits of Personally Identifiable Information

Not assessed

Progress: To do

Provide and implement the capability for auditing the parameters of user query events for data sets containing personally identifiable information.

AU-13 — Monitoring for Information Disclosure

Not assessed

Progress: To do

a. Monitor [Assignment: organization-defined open-source information and/or information sites] [Assignment: organization-defined frequency] for evidence of unauthorized disclosure of organizational information; and
b. If an information disclosure is discovered:
1. Notify [Assignment: organization-defined personnel or roles]; and
2. Take the following additional actions: [Assignment: organization-defined additional actions].

AU-13(1) — Monitoring for Information Disclosure | Use of Automated Tools

Not assessed

[Withdrawn: Incorporated into CA-2.]

CA-5 — Plan of Action and Milestones

Compliant

Progress: Done

a. Develop a plan of action and milestones for the system to document the planned remediation actions of the organization to correct weaknesses or deficiencies noted during the assessment of the controls and to reduce or eliminate known vulnerabilities in the system; and
b. Update existing plan of action and milestones [Assignment: organization-defined frequency] based on the findings from control assessments, independent audits or reviews, and continuous monitoring activities.

“Observation”: A POA&M is maintained across Labs 01-04 with sequential IDs, weakness, mapped control, severity, planned action, scheduled completion, and status. Items are closed only with evidence (e.g., POA&M-002 closed 2026-10-16 by authenticated scan; POA&M-003 closed via Lab 02).

“Evidences”: Lab 03 risk acceptance, Lab 02 asset inventory

CA-5(1) — Plan of Action and Milestones | Automation Support for Accuracy and Currency

Not assessed

Progress: To do

Ensure the accuracy, currency, and availability of the plan of action and milestones for the system using [Assignment: organization-defined automated mechanisms].

CA-6 — Authorization

Not assessed

Progress: To do

a. Assign a senior official as the authorizing official for the system;
b. Assign a senior official as the authorizing official for common controls available for inheritance by organizational systems;
c. Ensure that the authorizing official for the system, before commencing operations:
1. Accepts the use of common controls inherited by the system; and
2. Authorizes the system to operate;
d. Ensure that the authorizing official for common controls authorizes the use of those controls for inheritance by organizational systems;
e. Update the authorizations [Assignment: organization-defined frequency].

CA-6(1) — Authorization | Joint Authorization — Intra-organization

Not assessed

Progress: To do

Employ a joint authorization process for the system that includes multiple authorizing officials from the same organization conducting the authorization.

CA-6(2) — Authorization | Joint Authorization — Inter-organization

Not assessed

Progress: To do

Employ a joint authorization process for the system that includes multiple authorizing officials with at least one authorizing official from an organization external to the organization conducting the authorization.

CA-7 — Continuous Monitoring

Partially compliant

Progress: Done

Develop a system-level continuous monitoring strategy and implement continuous monitoring in accordance with the organization-level continuous monitoring strategy that includes:
a. Establishing the following system-level metrics to be monitored: [Assignment: organization-defined system-level metrics];
b. Establishing [Assignment: organization-defined frequencies] for monitoring and [Assignment: organization-defined frequencies] for assessment of control effectiveness;
c. Ongoing control assessments in accordance with the continuous monitoring strategy;
d. Ongoing monitoring of system and organization-defined metrics in accordance with the continuous monitoring strategy;
e. Correlation and analysis of information generated by control assessments and monitoring;

f. Response actions to address results of the analysis of control assessment and monitoring information; and
g. Reporting the security and privacy status of the system to [Assignment: organization-defined personnel or roles] [Assignment: organization-defined frequency].

“Observation”: The Configuration Baseline Standard requires scanning against the tailored profile before entering service, after significant change, and at least monthly. A find-fix-verify cycle was demonstrated with a GVM rescan and delta report. Gap: monitoring is manual and point-in-time; no automated scheduled scans or log monitoring yet.

“Evidences”: Lab 03 GVM authenticated scans

CA-7(1) — Continuous Monitoring | Independent Assessment

Not assessed

Progress: To do

Employ independent assessors or assessment teams to monitor the controls in the system on an ongoing basis.

CA-7(2) — Continuous Monitoring | Types of Assessments

Not assessed

Progress: To do

[Withdrawn: Incorporated into CA-2.]

CA-7(3) — Continuous Monitoring | Trend Analyses

Not assessed

Progress: To do

Employ trend analyses to determine if control implementations, the frequency of continuous monitoring activities, and the types of activities used in the continuous monitoring process need to be modified based on empirical data.

CA-7(4) — Continuous Monitoring | Risk Monitoring

Not assessed

Progress: To do

Ensure risk monitoring is an integral part of the continuous monitoring strategy that includes the following:
(a) Effectiveness monitoring;
(b) Compliance monitoring; and
(c) Change monitoring.

CA-7(5) — Continuous Monitoring | Consistency Analysis

Not assessed

Progress: To do

Employ the following actions to validate that policies are established and implemented controls are operating in a consistent manner: [Assignment: organization-defined actions].

CA-7(6) — Continuous Monitoring | Automation Support for Monitoring

Not assessed

Progress: To do

Ensure the accuracy, currency, and availability of monitoring results for the system using [Assignment: organization-defined automated mechanisms].

CA-8 — Penetration Testing

Not assessed

Progress: To do

Conduct penetration testing [Assignment: organization-defined frequency] on [Assignment: organization-defined systems or system components].

CA-8(1) — Penetration Testing | Independent Penetration Testing Agent or Team

Not assessed

Progress: To do

Employ an independent penetration testing agent or team to perform penetration testing on the system or system components.

CA-8(2) — Penetration Testing | Red Team Exercises

Not assessed

Progress: To do

Employ the following red-team exercises to simulate attempts by adversaries to compromise organizational systems in accordance with applicable rules of engagement: [Assignment: organization-defined red team exercises].

CA-8(3) — Penetration Testing | Facility Penetration Testing

Not assessed

Progress: To do

Employ a penetration testing process that includes [Assignment: organization-defined frequency] [Selection: announced; unannounced] attempts to bypass or circumvent controls associated with physical access points to the facility.

CA-9 — Internal System Connections

Not assessed

Progress: To do

a. Authorize internal connections of [Assignment: organization-defined system components or classes of components] to the system;
b. Document, for each internal connection, the interface characteristics, security and privacy requirements, and the nature of the information communicated;
c. Terminate internal system connections after [Assignment: organization-defined conditions]; and
d. Review [Assignment: organization-defined frequency] the continued need for each internal connection.

CA-9(1) — Internal System Connections | Compliance Checks

Not assessed

Progress: To do

Perform security and privacy compliance checks on constituent system components prior to the establishment of the internal connection.

CM-1 — Policy and Procedures

Not assessed

Progress: To do

a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:
1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] configuration management policy that:
(a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
(b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and
2. Procedures to facilitate the implementation of the configuration management policy and the associated configuration management controls;
b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the configuration management policy and procedures; and
c. Review and update the current configuration management:
1. Policy [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]; and
2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events].

CM-2 — Baseline Configuration

Compliant

Progress: Done

a. Develop, document, and maintain under configuration control, a current baseline configuration of the system; and
b. Review and update the baseline configuration of the system:
1. [Assignment: organization-defined frequency];
2. When required due to [Assignment: organization-defined circumstances]; and
3. When system components are installed or upgraded.

“Observation”: The approved baseline is CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0 Level 1 Server, delivered through SCAP Security Guide 0.1.82 and tailored in lab03-tailoring.xml (profile lab03_cis_l1_server_tailored). Snapshots preserve the pre-hardening and pre-remediation states.

“Evidences”: Lab 03 OpenSCAP reports & tailoring

CM-11(1) — User-installed Software | Alerts for Unauthorized Installations

Not assessed

Progress: To do

[Withdrawn: Incorporated into CM-8(3).]

CM-2(2) — Baseline Configuration | Automation Support for Accuracy and Currency

Not assessed

Progress: To do

Maintain the currency, completeness, accuracy, and availability of the baseline configuration of the system using [Assignment: organization-defined automated mechanisms].

CM-2(3) — Baseline Configuration | Retention of Previous Configurations

Not assessed

Progress: To do

Retain [Assignment: organization-defined number] of previous versions of baseline configurations of the system to support rollback.

CM-2(1) — Baseline Configuration | Reviews and Updates

Not assessed

Progress: To do

[Withdrawn: Incorporated into CM-2.]

CM-2(4) — Baseline Configuration | Unauthorized Software

Not assessed

Progress: To do

[Withdrawn: Incorporated into CM-7(4).]

CM-2(6) — Baseline Configuration | Development and Test Environments

Not assessed

Progress: To do

Maintain a baseline configuration for system development and test environments that is managed separately from the operational baseline configuration.

CM-2(7) — Baseline Configuration | Configure Systems and Components for High-risk Areas

Not assessed

Progress: To do

(a) Issue [Assignment: organization-defined systems or system components] with [Assignment: organization-defined configurations] to individuals traveling to locations that the organization deems to be of significant risk; and
(b) Apply the following controls to the systems or components when the individuals return from travel: [Assignment: organization-defined controls].

CM-3 — Configuration Change Control

Not assessed

Progress: To do

a. Determine and document the types of changes to the system that are configuration-controlled;
b. Review proposed configuration-controlled changes to the system and approve or disapprove such changes with explicit consideration for security and privacy impact analyses;
c. Document configuration change decisions associated with the system;
d. Implement approved configuration-controlled changes to the system;
e. Retain records of configuration-controlled changes to the system for [Assignment: organization-defined time period];
f. Monitor and review activities associated with configuration-controlled changes to the system; and
g. Coordinate and provide oversight for configuration change control activities through [Assignment: organization-defined configuration change control element] that convenes [Selection (one or more): [Assignment: organization-defined frequency]; when [Assignment: organization-defined configuration change conditions]].

CM-3(1) — Configuration Change Control | Automated Documentation, Notification, and Prohibition of Changes

Not assessed

CM-6 — Configuration Settings

Compliant

Progress: Done

a. Establish and document configuration settings for components employed within the system that reflect the most restrictive mode consistent with operational requirements using [Assignment: organization-defined common secure configurations];
b. Implement the configuration settings;
c. Identify, document, and approve any deviations from established configuration settings for [Assignment: organization-defined system components] based on [Assignment: organization-defined operational requirements]; and
d. Monitor and control changes to the configuration settings in accordance with organizational policies and procedures.

“Observation”: Settings were applied via a reviewed 398-fix remediation script plus manual fixes, raising the OpenSCAP score from 68.83 to 97.58 (tailored). All 112 baseline failures are dispositioned: 102 remediated, 7 not applicable, 3 risk-accepted. Each deviation is recorded in the deviation register with justification.

“Evidences”: Lab 03 OpenSCAP reports & tailoring

CM-6(1) — Configuration Settings | Automated Management, Application, and Verification

Not assessed

Progress: To do

Manage, apply, and verify configuration settings for [Assignment: organization-defined system components] using [Assignment: organization-defined automated mechanisms].

CM-6(2) — Configuration Settings | Respond to Unauthorized Changes

Not assessed

Progress: To do

Take the following actions in response to unauthorized changes to [Assignment: organization-defined configuration settings]: [Assignment: organization-defined actions].

CM-5(7) — Access Restrictions for Change | Automatic Implementation of Security Safeguards

Not assessed

Progress: To do

[Withdrawn: Incorporated into SI-7.]

CM-6(3) — Configuration Settings | Unauthorized Change Detection

Not assessed

Progress: To do

[Withdrawn: Incorporated into SI-7.]

CM-7 — Least Functionality

Partially compliant

Progress: Done

a. Configure the system to provide only [Assignment: organization-defined mission essential capabilities]; and
b. Prohibit or restrict the use of the following functions, ports, protocols, software, and/or services: [Assignment: organization-defined prohibited or restricted functions, system ports, protocols, software, and/or services].

“Observation”: Unused kernel modules and filesystems are disabled, cleartext client packages are removed, and /tmp is mounted noexec, nosuid, nodev. Postfix (installed as an AIDE dependency) listens on loopback only. Gap: some AppArmor profiles are not in enforce or complain mode.

“Evidences”: Lab 03 OpenSCAP reports & tailoring

CM-7(1) — Least Functionality | Periodic Review

Not assessed

Progress: To do

(a) Review the system [Assignment: organization-defined frequency] to identify unnecessary and/or nonsecure functions, ports, protocols, software, and services; and
(b) Disable or remove [Assignment: organization-defined functions, ports, protocols, software, and services within the system deemed to be unnecessary and/or nonsecure].

CM-7(2) — Least Functionality | Prevent Program Execution

Not assessed

Progress: To do

Prevent program execution in accordance with [Selection (one or more): [Assignment: organization-defined policies, rules of behavior, and/or access agreements regarding software program usage and restrictions]; rules authorizing the terms and conditions of software program usage].

CM-7(3) — Least Functionality | Registration Compliance

Not assessed

Progress: To do

Ensure compliance with [Assignment: organization-defined registration requirements for functions, ports, protocols, and services].

CM-7(4) — Least Functionality | Unauthorized Software — Deny-by-exception

Not assessed

Progress: To do

(a) Identify [Assignment: organization-defined software programs not authorized to execute on the system];
(b) Employ an allow-all, deny-by-exception policy to prohibit the execution of unauthorized software programs on the system; and
(c) Review and update the list of unauthorized software programs [Assignment: organization-defined frequency].

CM-7(5) — Least Functionality | Authorized Software — Allow-by-exception

Not assessed

Progress: To do

(a) Identify [Assignment: organization-defined software programs authorized to execute on the system];
(b) Employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs on the system; and
(c) Review and update the list of authorized software programs [Assignment: organization-defined frequency].

CM-7(6) — Least Functionality | Confined Environments with Limited Privileges

Not assessed

Progress: To do

Require that the following user-installed software execute in a confined physical or virtual machine environment with limited privileges: [Assignment: organization-defined user-installed software].

CM-7(7) — Least Functionality | Code Execution in Protected Environments

Not assessed

Progress: To do

Allow execution of binary or machine-executable code only in confined physical or virtual machine environments and with the explicit approval of [Assignment: organization-defined personnel or roles] when such code is:
(a) Obtained from sources with limited or no warranty; and/or
(b) Without the provision of source code.

CM-7(8) — Least Functionality | Binary or Machine Executable Code

Not assessed

Progress: To do

(a) Prohibit the use of binary or machine-executable code from sources with limited or no warranty or without the provision of source code; and
(b) Allow exceptions only for compelling mission or operational requirements and with the approval of the authorizing official.

CM-7(9) — Least Functionality | Prohibiting The Use of Unauthorized Hardware

Not assessed

Progress: To do

(a) Identify [Assignment: organization-defined hardware components authorized for system use];
(b) Prohibit the use or connection of unauthorized hardware components;
(c) Review and update the list of authorized hardware components [Assignment: organization-defined frequency].

CM-8 — System Component Inventory

Compliant

Progress: Done

a. Develop and document an inventory of system components that:
1. Accurately reflects the system;
2. Includes all components within the system;
3. Does not include duplicate accounting of components or components assigned to any other system;
4. Is at the level of granularity deemed necessary for tracking and reporting; and
5. Includes the following information to achieve system component accountability: [Assignment: organization-defined information deemed necessary to achieve effective system component accountability]; and
b. Review and update the system component inventory [Assignment: organization-defined frequency].

“Observation”: System components are inventoried from Lab 02 network enumeration and recorded in CISO Assistant as assets AST-001 (lab03-target, primary) and AST-002 (Kali-GVM-Scanner, supporting), with hardware, OS version, kernel, and network attributes documented in the SSP.

“Evidences”: Lab 02 asset inventory

CM-8(1) — System Component Inventory | Updates During Installation and Removal

Not assessed

Progress: To do

Update the inventory of system components as part of component installations, removals, and system updates.

CM-8(2) — System Component Inventory | Automated Maintenance

Not assessed

Progress: To do

Maintain the currency, completeness, accuracy, and availability of the inventory of system components using [Assignment: organization-defined automated mechanisms].

CM-8(3) — System Component Inventory | Automated Unauthorized Component Detection

Not assessed

Progress: To do

(a) Detect the presence of unauthorized hardware, software, and firmware components within the system using [Assignment: organization-defined automated mechanisms] [Assignment: organization-defined frequency]; and
(b) Take the following actions when unauthorized components are detected: [Selection (one or more): disable network access by such components; isolate the components; notify [Assignment: organization-defined personnel or roles]].

CM-8(4) — System Component Inventory | Accountability Information

Not assessed

Progress: To do

Include in the system component inventory information, a means for identifying by [Selection (one or more): name; position; role], individuals responsible and accountable for administering those components.

CM-6(4) — Configuration Settings | Conformance Demonstration

Not assessed

Progress: To do

[Withdrawn: Incorporated into CM-4.]

CM-8(6) — System Component Inventory | Assessed Configurations and Approved Deviations

Not assessed

Progress: To do

Include assessed component configurations and any approved deviations to current deployed configurations in the system component inventory.

CM-8(7) — System Component Inventory | Centralized Repository

Not assessed

Progress: To do

Provide a centralized repository for the inventory of system components.

Enforce dual authorization for the deletion or destruction of [Assignment: organization-defined backup information].

CP-9(8) — System Backup | Cryptographic Protection

Not assessed

Progress: To do

Implement cryptographic mechanisms to prevent unauthorized disclosure and modification of [Assignment: organization-defined backup information].

CP-10 — System Recovery and Reconstitution

Non compliant

Progress: Done

Provide for the recovery and reconstitution of the system to a known state within [Assignment: organization-defined time period consistent with recovery time and recovery point objectives] after a disruption, compromise, or failure.

"Observation": Recovery objectives are defined (RTO 24h, RPO 24h, MTD 72h), and VM snapshots exist. Gap: no documented, tested break-glass and recovery procedure. Recovery during Lab 03 required rescue media after the only administrator was locked out.

CP-5 — Contingency Plan Update

Not assessed

Progress: To do

[Withdrawn: Incorporated into CP-2.]

CP-10(2) — System Recovery and Reconstitution | Transaction Recovery

Not assessed

Progress: To do

Implement transaction recovery for systems that are transaction-based.

CP-7(5) — Alternate Processing Site | Equivalent Information Security Safeguards

Not assessed

Progress: To do

Withdrawn: Incorporated into CP-7.]

CP-10(4) — System Recovery and Reconstitution | Restore Within Time Period

Not assessed

Progress: To do

Provide the capability to restore system components within [Assignment: organization-defined restoration time periods] from configuration-controlled and integrity-protected information representing a known, operational state for the components.

CP-9(4) — System Backup | Protection from Unauthorized Modification

Not assessed

Progress: To do

[Withdrawn: Incorporated into CP-9.]

CP-10(6) — System Recovery and Reconstitution | Component Protection

Not assessed

Progress: To do

Protect system components used for recovery and reconstitution.

CP-11 — Alternate Communications Protocols

Not assessed

Progress: To do

Provide the capability to employ [Assignment: organization-defined alternative communications protocols] in support of maintaining continuity of operations.

CP-12 — Safe Mode

Not assessed

Progress: To do

When [Assignment: organization-defined conditions] are detected, enter a safe mode of operation with [Assignment: organization-defined restrictions of safe mode of operation].

CP-13 — Alternative Security Mechanisms

Not assessed

Progress: To do

Employ [Assignment: organization-defined alternative or supplemental security mechanisms] for satisfying [Assignment: organization-defined security functions] when the primary means of implementing the security function is unavailable or compromised.

IA-1 — Policy and Procedures

Not assessed

Progress: To do

a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:
1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] identification and authentication policy that:
(a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
(b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and
2. Procedures to facilitate the implementation of the identification and authentication policy and the associated identification and authentication controls;
b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the identification and authentication policy and procedures; and
c. Review and update the current identification and authentication:
1. Policy [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]; and
2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events].

IA-2 — Identification and Authentication (organizational Users)

Partially compliant

Progress: Done

Uniquely identify and authenticate organizational users and associate that unique identification with processes acting on behalf of those users.

“Observation”: Each user authenticates with a unique named account; shared and root SSH logins are not permitted. Gap: SSH uses password authentication without multi-factor authentication for the privileged account, which the Low baseline requires under IA-2(1).

“Evidences”: Lab 03 hardening screenshots (05-09)

IA-2(1) — Identification and Authentication (organizational Users) | Multi-factor Authentication to Privileged Accounts

Not assessed

Progress: To do

Implement multi-factor authentication for access to privileged accounts.

IA-2(2) — Identification and Authentication (organizational Users) | Multi-factor Authentication to Non-privileged Accounts

Not assessed

Progress: To do

Implement multi-factor authentication for access to non-privileged accounts.

IA-2(11) — Identification and Authentication (organizational Users) | Remote Access — Separate Device

Not assessed

Progress: To do

[Withdrawn: Incorporated into IA-2(6).]

IA-4(2) — Identifier Management | Supervisor Authorization

Not assessed

Progress: To do

[Withdrawn: Incorporated into IA-12(1).]

IA-4(3) — Identifier Management | Multiple Forms of Certification

Not assessed

Progress: To do

[Withdrawn: Incorporated into IA-12(2).]

IA-4(4) — Identifier Management | Identify User Status

Not assessed

Progress: To do

Manage individual identifiers by uniquely identifying each individual as [Assignment: organization-defined characteristic identifying individual status].

IA-4(5) — Identifier Management | Dynamic Management

Not assessed

Progress: To do

Manage individual identifiers dynamically in accordance with [Assignment: organization-defined dynamic identifier policy].

IA-4(6) — Identifier Management | Cross-organization Management

Not assessed

Progress: To do

Coordinate with the following external organizations for cross-organization management of identifiers: [Assignment: organization-defined external organizations].

IA-4(7) — Identifier Management | In-person Registration

Not assessed

Progress: To do

[Withdrawn: Incorporated into IA-12(4).]

IA-4(8) — Identifier Management | Pairwise Pseudonymous Identifiers

Not assessed

Progress: To do

Generate pairwise pseudonymous identifiers.

IA-4(9) — Identifier Management | Attribute Maintenance and Protection

Not assessed

Progress: To do

Maintain the attributes for each uniquely identified individual, device, or service in [Assignment: organization-defined protected central storage].

IA-5 — Authenticator Management

Compliant

Progress: Done

Manage system authenticators by:
a. Verifying, as part of the initial authenticator distribution, the identity of the individual, group, role, service, or device receiving the authenticator;
b. Establishing initial authenticator content for any authenticators issued by the organization;
c. Ensuring that authenticators have sufficient strength of mechanism for their intended use;
d. Establishing and implementing administrative procedures for initial authenticator distribution, for lost or compromised or damaged authenticators, and for revoking authenticators;
e. Changing default authenticators prior to first use;
f. Changing or refreshing authenticators [Assignment: organization-defined time period by authenticator type] or when [Assignment:

organization-defined events] occur;
g. Protecting authenticator content from unauthorized disclosure and modification;
h. Requiring individuals to take, and having devices implement, specific controls to protect authenticators; and
i. Changing authenticators for group or role accounts when membership to those accounts changes.

“Observation”: pam_pwquality enforces a minimum length of 14 with quality checks, and pam_pwhistory prevents reuse. Periodic forced expiration is not enforced, per NIST SP 800-63B and a documented risk acceptance memo (reviewed 2027-10-07); passwords are changed upon evidence of compromise. Note: The GVM application password policy on the supporting asset is tracked separately.

“Evidences”: Lab 03 risk acceptance, Lab 03 hardening screenshots (05-09)

IA-5(1) — Authenticator Management | Password-based Authentication

Not assessed

Progress: To do

For password-based authentication:
(a) Maintain a list of commonly-used, expected, or compromised passwords and update the list [Assignment: organization-defined frequency] and when organizational passwords are suspected to have been compromised directly or indirectly;
(b) Verify, when users create or update passwords, that the passwords are not found on the list of commonly-used, expected, or compromised passwords in IA-5(1)(a);
(c) Transmit passwords only over cryptographically-protected channels;
(d) Store passwords using an approved salted key derivation function, preferably using a keyed hash;
(e) Require immediate selection of a new password upon account recovery;
(f) Allow user selection of long passwords and passphrases, including spaces and all printable characters;
(g) Employ automated tools to assist the user in selecting strong password authenticators; and
(h) Enforce the following composition and complexity rules: [Assignment: organization-defined composition and complexity rules].

IA-5(2) — Authenticator Management | Public Key-based Authentication

Not assessed

Progress: To do

(a) For public key-based authentication:
(1) Enforce authorized access to the corresponding private key; and
(2) Map the authenticated identity to the account of the individual or group; and
(b) When public key infrastructure (PKI) is used:
(1) Validate certificates by constructing and verifying a certification path to an accepted trust anchor, including checking certificate status information; and
(2) Implement a local cache of revocation data to support path discovery and validation.

IA-5(11) — Authenticator Management | Hardware Token-based Authentication

Not assessed

Progress: To do

[Withdrawn: Incorporated into IA-2(1) and IA-2(2).]

IA-5(3) — Authenticator Management | In-person or Trusted External Party Registration

Not assessed

Progress: To do

[Withdrawn: Incorporated into IA-12(4).]

IA-5(5) — Authenticator Management | Change Authenticators Prior to Delivery

Not assessed

Progress: To do

Require developers and installers of system components to provide unique authenticators or change default authenticators prior to delivery and installation.

IA-5(6) — Authenticator Management | Protection of Authenticators

Not assessed

Progress: To do

Protect authenticators commensurate with the security category of the information to which use of the authenticator permits access.

RA-1 — Policy and Procedures

Not assessed

Progress: To do

a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:
1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] risk assessment policy that:
(a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
(b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and
2. Procedures to facilitate the implementation of the risk assessment policy and the associated risk assessment controls;
b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the risk assessment policy and procedures; and
c. Review and update the current risk assessment:
1. Policy [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]; and
2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events].

RA-2 — Security Categorization

Not assessed

Progress: To do

a. Categorize the system and information it processes, stores, and transmits;
b. Document the security categorization results, including supporting rationale, in the security plan for the system; and
c. Verify that the authorizing official or authorizing official designated representative reviews and approves the security categorization decision.

RA-2(1) — Security Categorization | Impact-level Prioritization

Not assessed

Progress: To do

Conduct an impact-level prioritization of organizational systems to obtain additional granularity on system impact levels.

RA-3 — Risk Assessment

Partially compliant

Progress: Done

a. Conduct a risk assessment, including:
1. Identifying threats to and vulnerabilities in the system;
2. Determining the likelihood and magnitude of harm from unauthorized access, use, disclosure, disruption, modification, or destruction of the system, the information it processes, stores, or transmits, and any related information; and
3. Determining the likelihood and impact of adverse effects on individuals arising from the processing of personally identifiable information;
b. Integrate risk assessment results and risk management decisions from the organization and mission or business process perspectives with system-level risk assessments;
c. Document risk assessment results in [Selection: security and privacy plans; risk assessment report; [Assignment: organization-defined document]];
d. Review risk assessment results [Assignment: organization-defined frequency];
e. Disseminate risk assessment results to [Assignment: organization-defined personnel or roles]; and
f. Update the risk assessment [Assignment: organization-defined frequency] or when there are significant changes to the system, its environment of operation, or other conditions that may impact the security or privacy state of the system.

“Observation”: Risks are assessed per finding, with likelihood and impact in two risk acceptance memos (password aging; inherited CPU mitigations). Gap: no system-level risk assessment register; to be built in CISO Assistant as part of this lab.

“Evidences”: Lab 03 risk acceptance

RA-3(1) — Risk Assessment | Supply Chain Risk Assessment

Not assessed

Progress: To do

(a) Assess supply chain risks associated with [Assignment: organization-defined systems, system components, and system services]; and
(b) Update the supply chain risk assessment [Assignment: organization-defined frequency], when there are significant changes to the relevant supply chain, or when changes to the system, environments of operation, or other conditions may necessitate a change in the supply chain.

RA-3(2) — Risk Assessment | Use of All-source Intelligence

Not assessed

Progress: To do

Use all-source intelligence to assist in the analysis of risk.

RA-3(3) — Risk Assessment | Dynamic Threat Awareness

Not assessed

Progress: To do

Determine the current cyber threat environment on an ongoing basis using [Assignment: organization-defined means].

RA-3(4) — Risk Assessment | Predictive Cyber Analytics

Not assessed

Progress: To do

Employ the following advanced automation and analytics capabilities to predict and identify risks to [Assignment: organization-defined systems or system components]: [Assignment: organization-defined advanced automation and analytics capabilities].

RA-4 — Risk Assessment Update

Not assessed

Progress: To do

[Withdrawn: Incorporated into RA-3.]

RA-5 — Vulnerability Monitoring and Scanning

Compliant

Progress: Done

a. Monitor and scan for vulnerabilities in the system and hosted applications [Assignment: organization-defined frequency and/or randomly in accordance with organization-defined process] and when new vulnerabilities potentially affecting the system are identified and reported;
b. Employ vulnerability monitoring tools and techniques that facilitate interoperability among tools and automate parts of the vulnerability management process by using standards for:
1. Enumerating platforms, software flaws, and improper configurations;
2. Formatting checklists and test procedures; and
3. Measuring vulnerability impact;
c. Analyze vulnerability scan reports and results from vulnerability monitoring;
d. Remediate legitimate vulnerabilities [Assignment: organization-defined response times] in accordance with an organizational assessment of risk;
e. Share information obtained from the vulnerability monitoring process and control assessments with [Assignment: organization-defined personnel or roles] to help eliminate similar vulnerabilities in other systems; and
f. Employ vulnerability monitoring tools that include the capability to readily update the vulnerabilities to be scanned.

“Observation”: Vulnerability scanning uses GVM (Greenbone Community Feed) from a dedicated Kali scanner. An authenticated scan over SSH as gvmscan on 2026-10-16 found 0 Critical, 0 High, 2 Medium, 1 Low; the Low finding was remediated and confirmed gone by a rescan and delta report. Authentication success is evidenced by the SSH Login Successful result (RA-5(5))

“Evidences”: Lab 03 GVM authenticated scans

RA-5(1) — Vulnerability Monitoring and Scanning | Update Tool Capability

Not assessed

Progress: To do

[Withdrawn: Incorporated into RA-5.]

RA-5(2) — Vulnerability Monitoring and Scanning | Update Vulnerabilities to Be Scanned

Not assessed

Progress: To do

Update the system vulnerabilities to be scanned [Selection (one or more): [Assignment: organization-defined frequency]; prior to a new scan; when new vulnerabilities are identified and reported].

RA-5(3) — Vulnerability Monitoring and Scanning | Breadth and Depth of Coverage

Not assessed

SC-12(4) — Cryptographic Key Establishment and Management | PKI Certificates

Not assessed

Progress: To do

[Withdrawn: Incorporated into SC-12(3).]

SC-4(2) — Information in Shared System Resources | Multilevel or Periods Processing

Not assessed

Progress: To do

Prevent unauthorized information transfer via shared resources in accordance with [Assignment: organization-defined procedures] when system processing explicitly switches between different information classification levels or security categories.

SC-5 — Denial-of-service Protection

Not assessed

Progress: To do

a. [Selection: Protect against; Limit] the effects of the following types of denial-of-service events: [Assignment: organization-defined types of denial-of-service events]; and
b. Employ the following controls to achieve the denial-of-service objective: [Assignment: organization-defined controls by type of denial-of-service event].

SC-5(1) — Denial-of-service Protection | Restrict Ability to Attack Other Systems

Not assessed

Progress: To do

Restrict the ability of individuals to launch the following denial-of-service attacks against other systems: [Assignment: organization-defined denial-of-service attacks].

SC-5(2) — Denial-of-service Protection | Capacity, Bandwidth, and Redundancy

Not assessed

Progress: To do

Manage capacity, bandwidth, or other redundancy to limit the effects of information flooding denial-of-service attacks.

SC-5(3) — Denial-of-service Protection | Detection and Monitoring

Not assessed

Progress: To do

(a) Employ the following monitoring tools to detect indicators of denial-of-service attacks against, or launched from, the system: [Assignment: organization-defined monitoring tools]; and
(b) Monitor the following system resources to determine if sufficient resources exist to prevent effective denial-of-service attacks: [Assignment: organization-defined system resources].

SC-6 — Resource Availability

Not assessed

Progress: To do

Protect the availability of resources by allocating [Assignment: organization-defined resources] by [Selection (one or more): priority; quota; [Assignment: organization-defined controls]].

SC-7 — Boundary Protection

Partially compliant

Progress: Done

a. Monitor and control communications at the external managed interfaces to the system and at key internal managed interfaces within the system;
b. Implement subnetworks for publicly accessible system components that are [Selection: physically; logically] separated from internal organizational networks; and
c. Connect to external networks or systems only through managed interfaces consisting of boundary protection devices arranged in accordance with an organizational security and privacy architecture.

“Observation”: lab03-target sits on the isolated VirtualBox NAT Network LabNet (10.0.5.0/24). UFW is active with default-deny inbound, and SSH is permitted only from 10.0.5.0/24; hardened kernel network parameters are applied, and TCP timestamps are disabled. Gaps: outbound traffic is allowed by default, and one listening port (likely SSH on IPv6) lacks a matching rule.

“Evidences”: Lab 03 OpenSCAP reports & tailoring, Lab 03 hardening screenshots (05-09)

SC-12(5) — Cryptographic Key Establishment and Management | PKI Certificates / Hardware Tokens

Not assessed

Progress: To do

[Withdrawn: Incorporated into SC-12(3).]

SC-13(1) — Cryptographic Protection | FIPS-validated Cryptography

Not assessed

Progress: To do

[Withdrawn: Incorporated into SC-13.]

SC-7(3) — Boundary Protection | Access Points

Not assessed

Progress: To do

Limit the number of external network connections to the system.

SC-7(4) — Boundary Protection | External Telecommunications Services

Not assessed

Progress: To do

(a) Implement a managed interface for each external telecommunication service;
(b) Establish a traffic flow policy for each managed interface;
(c) Protect the confidentiality and integrity of the information being transmitted across each interface;
(d) Document each exception to the traffic flow policy with a supporting mission or business need and duration of that need;
(e) Review exceptions to the traffic flow policy [Assignment: organization-defined frequency] and remove exceptions that are no longer supported by an explicit mission or business need;
(f) Prevent unauthorized exchange of control plane traffic with external networks;
(g) Publish information to enable remote networks to detect unauthorized control plane traffic from internal networks; and
(h) Filter unauthorized control plane traffic from external networks.

SC-7(5) — Boundary Protection | Deny by Default — Allow by Exception

Not assessed

Progress: To do

Deny network communications traffic by default and allow network communications traffic by exception [Selection (one or more): at managed interfaces; for [Assignment: organization-defined systems]].

SC-13(2) — Cryptographic Protection | NSA-approved Cryptography

Not assessed

Progress: To do

[Withdrawn: Incorporated into SC-13.]

SC-7(7) — Boundary Protection | Split Tunneling for Remote Devices

Not assessed

Progress: To do

Prevent split tunneling for remote devices connecting to organizational systems unless the split tunnel is securely provisioned using [Assignment: organization-defined safeguards].

SC-7(8) — Boundary Protection | Route Traffic to Authenticated Proxy Servers

Not assessed

Progress: To do

Route [Assignment: organization-defined internal communications traffic] to [Assignment: organization-defined external networks] through authenticated proxy servers at managed interfaces.

Progress: To do

Relocate [Assignment: organization-defined sensors and monitoring capabilities] to [Assignment: organization-defined locations] under the following conditions or circumstances: [Assignment: organization-defined conditions or circumstances].

SC-48(1) — Sensor Relocation | Dynamic Relocation of Sensors or Monitoring Capabilities

Not assessed

Progress: To do

Dynamically relocate [Assignment: organization-defined sensors and monitoring capabilities] to [Assignment: organization-defined locations] under the following conditions or circumstances: [Assignment: organization-defined conditions or circumstances].

SC-49 — Hardware-enforced Separation and Policy Enforcement

Not assessed

Progress: To do

Implement hardware-enforced separation and policy enforcement mechanisms between [Assignment: organization-defined security domains].

SC-50 — Software-enforced Separation and Policy Enforcement

Not assessed

Progress: To do

Implement software-enforced separation and policy enforcement mechanisms between [Assignment: organization-defined security domains].

SC-51 — Hardware-based Protection

Not assessed

Progress: To do

a. Employ hardware-based, write-protect for [Assignment: organization-defined system firmware components]; and
b. Implement specific procedures for [Assignment: organization-defined authorized individuals] to manually disable hardware write-protect for firmware modifications and re-enable the write-protect prior to returning to operational mode.

SI-1 — Policy and Procedures

Not assessed

Progress: To do

a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:
1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] system and information integrity policy that:
(a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
(b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and
2. Procedures to facilitate the implementation of the system and information integrity policy and the associated system and information integrity controls;
b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the system and information integrity policy and procedures; and
c. Review and update the current system and information integrity:
1. Policy [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]; and
2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events].

SI-2 — Flaw Remediation

Compliant

Progress: Done

a. Identify, report, and correct system flaws;
b. Test software and firmware updates related to flaw remediation for effectiveness and potential side effects before installation;
c. Install security-relevant software and firmware updates within [Assignment: organization-defined time period] of the release of the updates; and
d. Incorporate flaw remediation into the organizational configuration management process.

“Observation”: The OS was fully patched before the re-scan (35 pending security updates reduced to 0) and verified by a re-scan. Automatic security updates are enabled through unattended-upgrades (service enabled; APT::Periodic Update-Package-Lists and

Unattended-Upgrade set to 1, verified 2026-10-19). Two Medium CPU-mitigation findings are inherited from the host firmware and VirtualBox and are risk-accepted with compensating controls (reviewed 2027-04-16).

"Evidences": Lab 03 OpenSCAP reports & tailoring, Lab 03 risk acceptance, Lab 03 GVM authenticated scans, Lab 04 logging & patching check

SI-13(2) — Predictable Failure Prevention | Time Limit on Process Execution Without Supervision

Not assessed

Progress: To do

[Withdrawn: Incorporated into SI-7(16).]

SI-2(2) — Flaw Remediation | Automated Flaw Remediation Status

Not assessed

Progress: To do

Determine if system components have applicable security-relevant software and firmware updates installed using [Assignment: organization-defined automated mechanisms] [Assignment: organization-defined frequency].

SI-2(3) — Flaw Remediation | Time to Remediate Flaws and Benchmarks for Corrective Actions

Not assessed

Progress: To do

(a) Measure the time between flaw identification and flaw remediation; and
(b) Establish the following benchmarks for taking corrective actions: [Assignment: organization-defined benchmarks].

SI-2(4) — Flaw Remediation | Automated Patch Management Tools

Not assessed

Progress: To do

Employ automated patch management tools to facilitate flaw remediation to the following system components: [Assignment: organization-defined system components].

SI-2(5) — Flaw Remediation | Automatic Software and Firmware Updates

Not assessed

Progress: To do

Install [Assignment: organization-defined security-relevant software and firmware updates] automatically to [Assignment: organization-defined system components].

SI-2(6) — Flaw Remediation | Removal of Previous Versions of Software and Firmware

Not assessed

Progress: To do

Remove previous versions of [Assignment: organization-defined software and firmware components] after updated versions have been installed.

SI-3 — Malicious Code Protection

Not assessed

Progress: To do

a. Implement [Selection (one or more): signature based; non-signature based] malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code;
b. Automatically update malicious code protection mechanisms as new releases are available in accordance with organizational configuration management policy and procedures;
c. Configure malicious code protection mechanisms to:
1. Perform periodic scans of the system [Assignment: organization-defined frequency] and real-time scans of files from external sources at [Selection (one or more): endpoint; network entry and exit points] as the files are downloaded, opened, or executed in accordance with organizational policy; and
2. [Selection (one or more): block malicious code; quarantine malicious code; take [Assignment: organization-defined action]]; and send alert to [Assignment: organization-defined personnel or roles] in response to malicious code detection; and
d. Address the receipt of false positives during malicious code detection and eradication and the resulting potential impact on the availability of the system.

Progress: To do

Provide visibility into network traffic at external and key internal system interfaces to optimize the effectiveness of monitoring devices.

SI-5 — Security Alerts, Advisories, and Directives

Not assessed

Progress: To do

a. Receive system security alerts, advisories, and directives from [Assignment: organization-defined external organizations] on an ongoing basis;
b. Generate internal security alerts, advisories, and directives as deemed necessary;
c. Disseminate security alerts, advisories, and directives to: [Selection (one or more): [Assignment: organization-defined personnel or roles]; [Assignment: organization-defined elements within the organization]; [Assignment: organization-defined external organizations]]; and
d. Implement security directives in accordance with established time frames, or notify the issuing organization of the degree of noncompliance.

SI-5(1) — Security Alerts, Advisories, and Directives | Automated Alerts and Advisories

Not assessed

Progress: To do

Broadcast security alert and advisory information throughout the organization using [Assignment: organization-defined automated mechanisms].

SI-6 — Security and Privacy Function Verification

Not assessed

Progress: To do

a. Verify the correct operation of [Assignment: organization-defined security and privacy functions];
b. Perform the verification of the functions specified in SI-6a [Selection (one or more): [Assignment: organization-defined system transitional states]; upon command by user with appropriate privilege; [Assignment: organization-defined frequency]];
c. Alert [Assignment: organization-defined personnel or roles] to failed security and privacy verification tests; and
d. [Selection (one or more): Shut the system down; Restart the system; [Assignment: organization-defined alternative action(s)]] when anomalies are discovered.

SI-4(8) — System Monitoring | Protection of Monitoring Information

Not assessed

Progress: To do

[Withdrawn: Incorporated into SI-4.]

SI-6(2) — Security and Privacy Function Verification | Automation Support for Distributed Testing

Not assessed

Progress: To do

Implement automated mechanisms to support the management of distributed security and privacy function testing.

SI-6(3) — Security and Privacy Function Verification | Report Verification Results

Not assessed

Progress: To do

Report the results of security and privacy function verification to [Assignment: organization-defined personnel or roles].

SI-7 — Software, Firmware, and Information Integrity

Compliant

Progress: Done

a. Employ integrity verification tools to detect unauthorized changes to the following software, firmware, and information: [Assignment: organization-defined software, firmware, and information]; and
b. Take the following actions when unauthorized changes to the software, firmware, and information are detected: [Assignment: organization-defined actions].

“Observation”: AIDE file integrity monitoring is installed and initialized with the CIS Level 1 baseline database.

"Evidences": Lab 03 OpenSCAP reports & tailoring

SI-7(1) — Software, Firmware, and Information Integrity | Integrity Checks

Not assessed

Progress: To do

Perform an integrity check of [Assignment: organization-defined software, firmware, and information] [Selection (one or more): at startup; at [Assignment: organization-defined transitional states or security-relevant events]; [Assignment: organization-defined frequency]].

SI-7(2) — Software, Firmware, and Information Integrity | Automated Notifications of Integrity Violations

Not assessed

Progress: To do

Employ automated tools that provide notification to [Assignment: organization-defined personnel or roles] upon discovering discrepancies during integrity verification.

SI-7(3) — Software, Firmware, and Information Integrity | Centrally Managed Integrity Tools

Not assessed

Progress: To do

Employ centrally managed integrity verification tools.

SI-6(1) — Security and Privacy Function Verification | Notification of Failed Security Tests

Not assessed

Progress: To do

[Withdrawn: Incorporated into SI-6.]

SI-7(5) — Software, Firmware, and Information Integrity | Automated Response to Integrity Violations

Not assessed

Progress: To do

Automatically [Selection (one or more): shut the system down; restart the system; implement [Assignment: organization-defined controls]] when integrity violations are discovered.

SI-7(6) — Software, Firmware, and Information Integrity | Cryptographic Protection

Not assessed

Progress: To do

Implement cryptographic mechanisms to detect unauthorized changes to software, firmware, and information.

SI-7(7) — Software, Firmware, and Information Integrity | Integration of Detection and Response

Not assessed

Progress: To do

Incorporate the detection of the following unauthorized changes into the organizational incident response capability: [Assignment: organization-defined security-relevant changes to the system].

SI-7(8) — Software, Firmware, and Information Integrity | Auditing Capability for Significant Events

Not assessed

Progress: To do

Upon detection of a potential integrity violation, provide the capability to audit the event and initiate the following actions: [Selection (one or more): generate an audit record; alert current user; alert [Assignment: organization-defined personnel or roles]; [Assignment: organization-defined other actions]].

SI-7(9) — Software, Firmware, and Information Integrity | Verify Boot Process

Not assessed

Progress: To do